

银行业防御 AI 代理网关架构设计方案

当前 Demo 基线、目标架构与企业化演进

安全架构与 AI 工程联合评审

2026-07-15

版本：v1.2 (Demo 基线更新版)

适用范围：银行内网防御 AI 告警分析、证据治理、受控建议与审计

状态口径：严格区分已实现、部分实现和目标态

核心判断

防御 AI 代理网关应定位为“安全产品与分析师之间的受控智能中枢”。它不替代 HIPS、RASP、NDR、WAF、SIEM，也不绕过 IAM、工单、SOAR 和变更流程；它负责把多源告警组织为可追溯 Case，在确定性策略、产品专属 Agent、受控模型、人工审批和审计约束下，提高研判一致性与经验复用效率。

当前仓库已经形成可运行的 Demo 基线：五产品接入、真实日志适配、持久异步队列、可插拔 LLM、产品 Agent、Validator、审批状态机、多层记忆、Dashboard、审计及离线部署物料。企业数据源、生产数据库、身份平台、向量服务和处置系统仍是下一阶段集成内容。

目录

章节	内容	章节	内容
1	文档目的与状态口径	9	多层记忆与匹配治理
2	建设目标、原则与边界	10	数据模型与 Dashboard
3	当前项目全面复核	11	安全、身份与生产边界
4	当前 Demo 运行架构	12	部署与离线迁移
5	目标架构与当前架构的衔接	13	Demo 验收基线
6	接入、路由与日志适配	14	生产差距与路线图
7	Agent、Skill、Validator 与审批	15	验收指标
8	LLM Gateway 与模型信任边界	16	结论与附录

1. 文档目的与状态口径

1.1 文档目的

本方案同时回答三个问题：

- 1. 最初的产品设计原则是什么，当前实现是否偏离；
- 2. 当前 Demo 已经真实实现了什么，边界在哪里；
- 3. 从 Demo 进入银行内网 PoC 和生产，需要替换或新增哪些组件。

1.2 状态定义

状态	定义	表述规则
已实现	当前仓库存在可运行代码，并有测试、API、数据库或 Demo 记录支持	可在演示中直接展示
部分实现	已有内部契约或简化实现，但未接入企业组件或未做生产验证	必须同时说明限制
目标态	当前仓库尚无对应生产能力	只能作为路线图或架构建议

1.3 版本变更

版本	日期	变化
v1.0	2026-06-24	提出受控智能中枢、八层架构、双通道、Agent/Skill/Harness、四层记忆与一层证据
v1.2	2026-07-15	对齐当前代码；加入 durable inbox、Validator/审批、MemoryMatcher、生产鉴权与部署治理；更新 Demo 量化成果和生产差距

2. 建设目标、原则与边界

2.1 建设目标

在受控服务器、私有云或 Kubernetes 集群内建设防御 AI 代理网关，统一接入安全产品告警和 SIEM 聚合事件，将原始证据、归一化事件、历史上下文和分析结论组织成可解释、可验证、可追责的 Case。

目标价值：

- 缩短多源告警从接收到初判的路径；
- 固化产品专属分析方法，降低研判质量对个人经验的依赖；

- 保留证据和缺口，避免模型用流畅语言掩盖不确定性；
- 把误报经验变成有来源、有范围、有过期时间的受控记忆；
- 把处置建议放入人工审批和既有流程，而不是赋予模型生产执行权；
- 在无互联网或受限网络中仍可部署、回放和审计。

2.2 设计原则

原则	架构要求	当前实现
证据优先	每个结论引用 Alert/Event/Case/Evidence，明确缺失证据	已实现
最小权限	工具和动作默认只读，高影响动作需审批	已实现 Demo 契约
上下文隔离	产品 Agent、Skill、Prompt 和长期记忆分区	已实现
可回放评测	运行路径可离线重放，变更需质量门禁	Harness 已实现，CI/Golden set 部分实现
人工在环	建议可审批，但批准不等于执行	已实现
合规内建	脱敏、端点限制、身份、审计、保留策略作为系统能力	已实现基础控制，企业 DLP/IAM 部分实现
失败可见	LLM/队列/监听异常可观测、可降级、可追溯	已实现

2.3 非目标

- 不提供攻击利用、真实凭证采集、未授权探测或主动扫描能力。
- 不直接执行封禁、隔离、停账号、策略变更或 SOAR 动作。
- 不把模型输出、Demo 标签或长期记忆视为不可质疑的事实。
- 不在 Demo 中模拟一个不存在的 CMDB、IAM、Kafka、PostgreSQL 或 SOAR 集成。

3. 当前项目全面复核

3.1 复核结论

当前实现总体符合最初路线，且治理能力比 v1.0 方案中的早期 MVP 预期更完整。主要偏差不是产品方向偏移，而是旧文档将“目标态”和“当前态”混写，容易产生以下误解：

- 把推荐的 PostgreSQL、向量库、图数据库写成当前已部署；
- 把产品直达 + SIEM Fusion 的目标编排写成当前完整多 Agent 攻击链；

- 把 Demo 样本真值校正后的稳定输出理解为模型准确率；
- 把内部审批状态机理解为已经接入 SOAR 并完成处置；
- 把 mTLS、RBAC 等目标控制理解为应用进程自身已经实现。

3.2 当前能力状态矩阵

能力域	状态	当前实现	生产差距
HTTP 告警入口	已实现	POST /api/alerts，鉴权、限流、大小限制、202	需 API Gateway/mTLS/WAF 与生产流量基线
Syslog 接入	已实现 Demo	五产品 TCP/UDP 端口；内嵌接收器；Vector Collector 清单	需真实设备联调、TLS relay、Collector HA 与容量验证
日志适配	已实现	Mapping Profile、infer、dry-run、自动指纹、五产品 auto profile	需厂商版本模板库和变更治理
持久队列	已实现	SQLite inbox、pending/retry/processing/completed/DLQ、重启恢复	生产高吞吐需评估 PostgreSQL/消息队列
Case 与关联	已实现	幂等 Event、Case 关联、终态滚动、15 分钟跨产品实体上下文	尚无完整攻击图、跨租户隔离和复杂 fusion planner
Product Agent	已实现	HIPS/RASP/NDR/WAF/SIEM 五个 Agent 和 Skill	外部只读工具与企业上下文尚未接入
Validator	已实现	契约、证据、注入、敏感信息、动作和 Skill 边界检查	需真实对抗集和组织规则扩展
Response Advisor	已实现	建议动作、approve_required、回滚条件	未接工单/SOAR 执行适配器
审批	已实现但不执行	单签 Demo、双签生产配置、distinct actor、单向状态机	需企业 IAM 主体、职责分离和签名回写

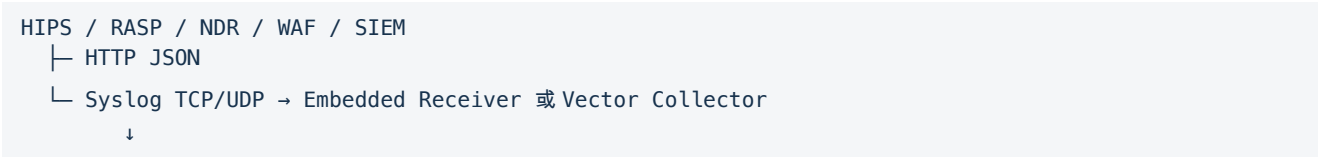
能力域	状态	当前实现	生产差距
多层记忆	已实现	四层记忆 + 只读证据；生命周期治理	CMDB/知识库来源、批量治理和企业保留策略待接入
语义匹配	已实现 Demo	稳定哈希向量 + 结构化 + retrieval key 混合评分	企业 Embedding、pgvector、规模和漂移评估
LLM Gateway	已实现	local/Ollama/gateway；Messages/通用JSON；超时、重试、熔断、响应上限	企业 DLP、成本、租户配额、集中模型审计
Dashboard	已实现	监控、Case、记忆、接入、配置；角色感知	SOC Portal/SSO、推送、HA 与可观测平台集成
Harness	部分实现	CLI 回放、随机样本、真实日志映射、Validator 门禁	私有 Golden set、CI 报告、质量基线、审批准布
离线部署	已实现物料	Docker/systemd/k3s、镜像 digest、Secret、TLS Ingress、回滚	需目标环境演练、镜像扫描、备份恢复与 DR 验证

3.3 工程质量快照

- Python 标准库优先，静态 Dashboard 无 npm 构建依赖；文档生成工具不属于运行时依赖。
- SQLite Schema 当前为 v9，可从历史版本前向迁移。
- 当前代码发现 183 个测试方法，覆盖接入可靠性、模型信任、记忆匹配、审批、生产边界和部署治理。
- 本轮完整测试运行 181 通过、2 个现有断言失败：错误文案匹配和 trusted sample 预期差异。发布前应恢复全绿，不应把 181/183 表述为生产验收通过。

4. 当前 Demo 运行架构

4.1 端到端数据流





4.2 告警生命周期与指标

状态/指标	含义
pending	已持久化，尚未被 dispatcher claim
retry	前次执行失败，等待下次可用时间
processing	已被 dispatcher claim；可能正在 worker 分析，也可能在执行队列等待
completed	Case 和结果已经成功提交
dead_letter	有限重试耗尽，保留原始告警和错误供人工处理
unfinished	pending + retry + processing，代表尚未完成分析的总量
queued	未占用 worker、仍在等待的数量
inflight	worker 正在分析的数量

Demo 默认 queue_max_size=5000、workers=4。批量提交 15 条时，系统可观测到 unfinished=15 / queued=11 / inflight=4，证明 HTTP 接收和 LLM 分析已经解耦。

4.3 事务与幂等

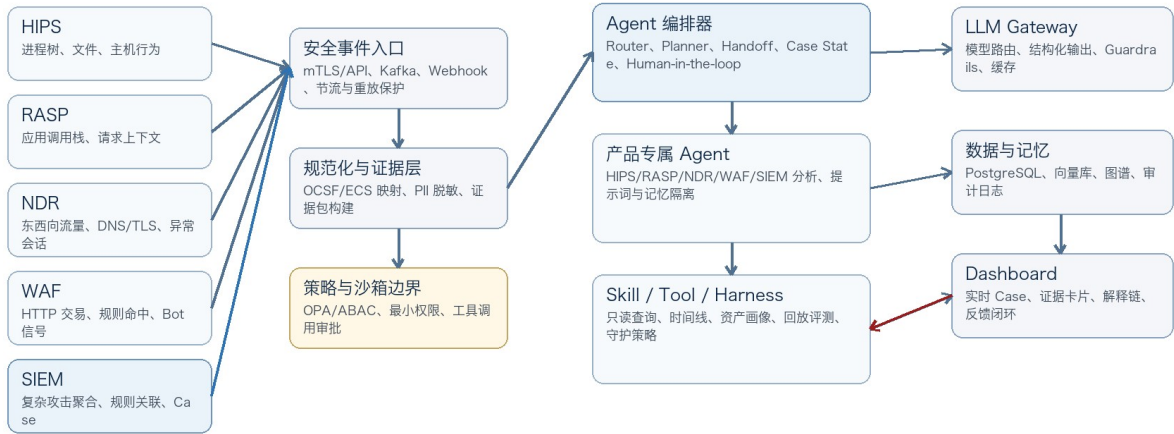
- 4. HTTP 返回 202 前，RawAlert 封装先写入 durable inbox。
- 5. Orchestrator 先以事务写入 audit、raw alert 和 normalized event；LLM 调用不持有数据库事务锁。
- 6. 相同 alert_id 的重复投递复用已持久化的 Event 和 Agent Result，不重复调用模型。
- 7. Case、Agent Run、Memory Match、Approval 和 Audit 以原子方式提交，避免“页面有 Case、审计无记录”或相反状态。
- 8. 进程异常后 stale processing 可恢复为 retry；重试耗尽进入 DLQ。

5. 目标架构与当前架构的衔接

下图保留 v1.0 的目标态思想，作为企业 PoC/生产演进方向，而不是当前 Demo 部署清单。

防御 AI 代理网关总体架构

两条告警路径：产品直达低/中复杂度分析；SIEM 聚合后进入复杂/高置信度分析



安全控制面：零信任入口、证据脱敏、只读工具优先、主动处置需审批、全链路审计、评测门禁
运行面：每个 Case 一个短期工作记忆；每个产品一套长期记忆；每个 Skill 独立权限、版本、测试与回滚。

图 1：防御 AI 代理网关目标架构（目标态）

目标态与当前实现的对应关系：

目标层	当前 Demo	企业化替换/增强
安全事件入口	Python HTTP Server、Embedded/Vector Syslog	API Gateway、mTLS、Kafka、厂商 API、重放保护
规范化与证据	Mapping Profile、Normalizer、SQLite evidence	企业数据字典、OCSF/ECS 映射、对象存储/证据库
策略与沙箱	PolicyEngine、角色 Token、allowlist、只读工具	IAM/ABAC/OPA、机密管理、DLP、网络微隔离
Agent 编排	单产品 Agent + 跨产品上下文	Planner/Fusion、企业只读工具、长运行 workflow
LLM Gateway	内置 provider adapter	企业模型网关、配额、成本、集中审计和模型评测
数据与记忆	SQLite、稳定哈希向量	PostgreSQL、Embedding/pgvector、实体关系服务
Dashboard	静态单体 UI	SOC Portal、SSO、实时推送、统一可观测
Harness	CLI + tests	Golden set、CI 门禁、版本差异报告、人工审批发布

6. 接入、路由与日志适配

6.1 接入优先级

显式 profile 参数/请求体 profile_id

→ 标准 RawAlert (显式 product)

→ 厂商日志内容指纹识别

→ 可验证的标准告警启发式

→ 无法识别则 400 拒绝

网关不应把未知来源静默降级为 SIEM，因为错误产品会选择错误 Agent、错误 Profile 和错误记忆命名空间。

6.2 Mapping Profile

Profile 负责把厂商原始日志转换为内部稳定 RawAlert：

- JSON 路径映射，例如 \$.metadata.id → alert_id；
- 产品和严重级别映射；
- 受控 transform，例如从 RASP stack trace 提取危险 sink；
- 原始日志保留、关键字段展开和 adapter 元数据；
- 必填字段校验和错误提示；
- infer + dry-run + 保存后再进入正式接入。

五产品内置 auto-<product>-json，Vector Collector 与这些 ID 对齐。生产仍应使用脱敏真实日志建立厂商/版本专用 Profile，并把 Profile 变更纳入回放和审批。

6.3 Syslog

产品	默认端口	推荐
WAF	15140	TCP 优先，UDP 仅在设备受限时使用
HIPS	15141	端口路由优先于报文 product 字段
NDR	15142	Collector 使用独立 ingest Token
RASP	15143	保留 stack trace 等长字段
SIEM	15144	聚合事件仍进入统一 RawAlert/Case 模型

生产推荐独立 Vector Collector，使用磁盘 buffer、来源 CIDR、NetworkPolicy 和受限 ingest Token。传统明文 Syslog 应置于设备专网/VPN，或由企业 TLS Syslog relay 终止。

7. Agent、Skill、Validator 与审批

7.1 产品专属 Agent

Agent	输入重点	研判重点
HIPS	进程树、签名/哈希、命令行、登录来源、主机动作	提权、驻留、横向、脚本与运维窗口
RASP	route、stack trace、taint、sink、应用动作	是否触达危险函数、是否阻断、业务影响
NDR	flow、DNS/TLS、周期性、数据量、网络分区	C2、横向、扫描、隧道和数据外传
WAF	URI、方法、规则、Header/参数类别、响应、会话	攻击尝试、规则效果、业务误拦截和调优建议
SIEM	时间线、规则链、实体、多源证据、SLA	聚合结论、影响面、证据冲突和下一步验证

7.2 Skill 契约

每个 Skill 声明：

- name/version/owner/product/capability；
- risk_level；
- allowed_inputs/allowed_tools/blocked_tools；
- output_schema/memory_namespace。

注册时 fail closed：产品分析必须解析到唯一 Skill；任何 Skill 都必须显式阻断 execute_production_action；同一工具不得同时出现在 allowlist 和 blocklist。

7.3 Validator

Validator 不调用 LLM，避免概率模型自证正确。状态含义：

状态	处理
passed	输出契约、证据、敏感信息、动作和 Skill 边界通过，可交给 Response Advisor
review	发现提示注入或非阻断证据缺口，保留结果供人工复核，不生成审批
blocked	发现结构、敏感数据、高风险证据或越权问题，阻断审批和可消费记忆写入

7.4 审批状态机

```
pending → approved
         → rejected
         → cancelled
```

- actor 由 Bearer Token 对应的服务端主体注入，客户端 actor 不可信；
- 生产模板要求不同主体双签；Demo 可单签；
- 重复投票不增加票数；拒绝或 Case 终态可取消 pending；
- 数据库约束 `execution_status=not_executed`；没有 `execute API`。

未来接入 SOAR 时应使用独立的执行请求、签名、幂等键、结果回写和回滚证据表。

8. LLM Gateway 与模型信任边界

8.1 Provider 抽象

Provider	用途	安全控制
local	离线、确定性回放和模型故障降级	无网络；输出可解释但能力有限
ollama	本地模型验证	默认 loopback；端点校验；模型列表与超时控制
gateway	企业/外部网关	HTTPS (非 loopback)、allowed_hosts、Token 同源、限时/重试/熔断/响应大小

当前运行时设置已保存为：`gateway / claude-sonnet-4-6 / https://kkcoder.com/v1/messages`。配置文件 `config/dev.yaml` 仍以 `local` 为默认，数据库 runtime setting 会在启动时恢复操作员选择。

8.2 分析与降级

- Product Agent 构造脱敏、限长 prompt 和结构化上下文。
- Gateway 返回 JSON 或 Messages 文本，由适配器解析并校验分类形状。
- Agent 对分类、verdict 和维度做一致性检查；未知分类降级为 `insufficient_evidence`。
- Gateway/网络异常写审计并使用 `LocalHeuristicLLM`；结果标记 `fallback_used` 和 `effective_provider=local`。
- 模型结果不能绕过 Validator、审批和恶意证据否决权。

8.3 Demo 样本真值

受信 Demo 请求的 `expected_verdict` 用于校正展示一致性。该机制仅在回环、无 Token、带专用 Header 时生效，普通入站告警会剥离这些控制字段。

质量验收必须另建不带 Demo Header 的盲测集，至少报告：分类准确率、严重误判率、置信度校准、证据引用正确率、输出契约成功率、P95/P99 延迟和降级比例。

9. 多层记忆与匹配治理

9.1 四层记忆 + 一层证据

层级	命名空间	当前用途	治理
Case 短期记忆	case/{case_id}	当前 Case 摘要和缺口，24h TTL	Case 关闭归档，不自动成为长期事实
产品长期记忆	product/{product}	已审批误报模式和产品经验	五道门禁、过期、冲突、隔离、撤销
资产画像	asset/{asset_id}	主机/应用/来源上下文	当前从事件派生，生产应接 CMDB/Owner
组织知识	org/{scope}	Playbook、事件分级、审批规则	当前内置只读种子，生产由治理团队维护
证据	immutable refs	NormalizedEvent 中的脱敏证据	Agent 只读，不可改写

9.2 MemoryMatcher

模型调用前，统一执行跨 provider 的确定性匹配：

```
overall = 0.68 × structured
          + 0.22 × semantic_vector
          + 0.10 × retrieval_key
```

默认 review_threshold=0.58、apply_threshold=0.78。只有 active、人工批准、未过期、medium/high trust 且通过敏感性检查的产品长期记忆可进入消费路径。

模型返回后再次做确定性合并：高分误报记忆可以支持 suspicious 降级，但当前告警中可核验的恶意证据拥有否决权。每个候选的结构化分、语义分、检索分、命中特征、排名、决策和最终影响写入 memory_matches。

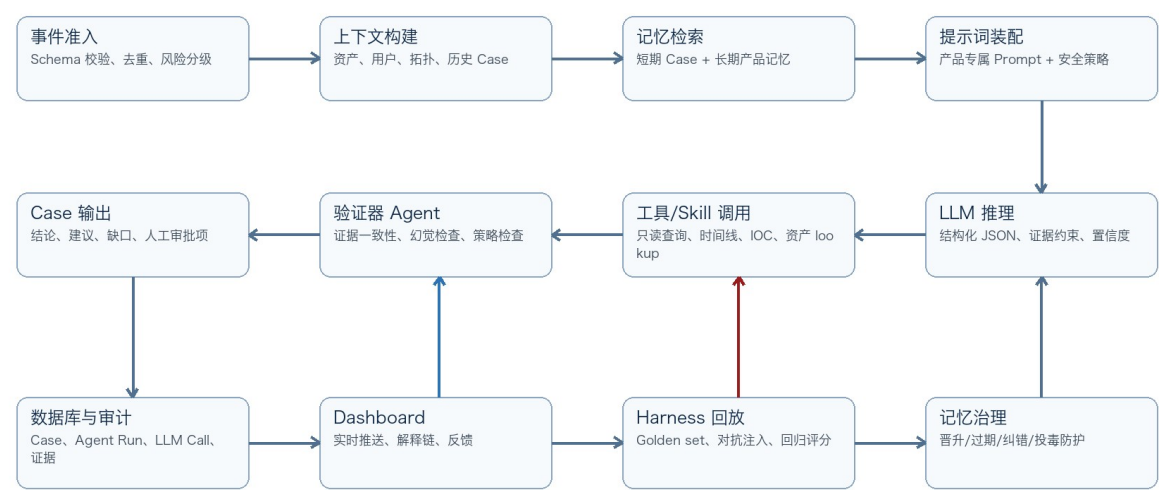
9.3 晋升门禁

长期记忆必须同时满足：

- 14. evidence_traceable：来源 Case 和证据可追溯；
- 15. analyst_approved：明确分析师主体；
- 16. scope_clear：适用范围明确；
- 17. expiry_set：过期时间明确且在未来；
- 18. no_sensitive_leak：内容经脱敏不发生敏感泄漏。

Agent / Skill / Harness 运行闭环

参考先进 agent runtime 的思想：状态持久化、工具隔离、技能复用、回放评测、人工确认



- 关键原则
- 1. 所有动作先进入策略沙箱，主动阻断/隔离类动作必须走审批或 SOAR 既有流程。
 - 2. 记忆不是事实真相；只有带证据来源、时间戳、审批状态的记忆可进入生产提示词。
 - 3. Harness 不只是测试模型，还测试 prompt、skill、检索、结构化输出和工具权限边界。

图 2：Agent / Skill / Harness 与记忆治理目标闭环（目标态）

10. 数据模型与 Dashboard

10.1 当前事实模型（SQLite v9）

表	作用
raw_alerts	原始告警和受信 Demo 标志
normalized_events	归一化事件、实体、证据、敏感标签
durable_alert_inbox	接入状态、重试、claim、完成和错误
cases / case_alert_links	Case 事实与多告警关联
agent_runs	Agent、prompt version、结构化结果、model runtime
validation_runs	Validator 状态、检查项和原因
action_approvals / approval_votes	建议审批、法定票数、主体和不可执行状态
memory_entries / memory_events	多层记忆与生命周期审计
memory_matches	后续告警与长期记忆的评分和影响
audit_log	接入、分析、配置、治理、审批等全链路审计
runtime_settings	受控保存 LLM/Syslog 操作员设置，不保存 API Key

10.2 Dashboard 模块

模块	当前能力
监控大屏	告警/Case、严重度、产品和分类分布、队列、模型和 Syslog 健康度
处置台	Case 详情、原始告警、证据、模型解释、Validation、审批、逐告警 disposition
记忆治理	概览、检索、门禁、晋升、拒绝、隔离、恢复、sweep、匹配分解、审计
日志接入	HTTP/Syslog 状态、Profile、infer、dry-run、样本加载
运行配置	local/Ollama/Gateway 切换、模型连接测试、Syslog 端口配置

前端每 5 秒刷新监控数据。待处理 KPI 使用 `unfinished`，健康区进一步显示 `queued` 和 `inflight`，避免 dispatcher 提前 claim 后页面错误显示为零。

11. 安全、身份与生产边界

11.1 六类风险控制

风险	当前控制	企业增强
幻觉/误判	证据锚定、结构化契约、Validator、确定性降级	Blind set、模型校准、双模型/人工复核策略
敏感泄漏	prompt 前脱敏、长度限制、端点限制、原文本地留存	DLP、字段级策略、密钥管理、出域审批
过度代理	read_only、blocked tools、approve_required、无 execute	IAM 职责分离、SOAR 签名执行与回滚
提示注入/投毒	Validator、受信样本边界、记忆门禁、隔离和冲突检测	专用红队集、内容来源签名、知识库变更审批
审计合规	全链路 SQLite 审计、身份覆盖客户端 actor	集中审计、WORM/不可抵赖存储、SIEM 监控
模型/供应链	Provider 可切、allowlist、超时/熔断、离线包	SBOM、镜像签名、模型供应商评估、配额与成本治理

11.2 身份与角色

生产模板区分 ingest、read、analyst、config、approver 等角色，并要求 API/ingest/operator/approver Token 不同。Collector 仅持有 ingest Token。审批主体由服务端凭据映射，不接受客户端自报 actor。Token 只是当前低依赖实现。企业 PoC 应由 API Gateway/SSO/IAM 提供短期身份、mTLS 和审计上下文，网关只消费经过验证的主体与角色声明。

11.3 网络与 TLS

- 开发默认仅监听 127.0.0.1 ；
- 生产应用仍建议绑定回环或 ClusterIP ；
- 外部访问必须经过 TLS/mTLS 反向代理或 Ingress ；
- Gateway 非 loopback 端点必须 HTTPS 且主机在 allowlist ；
- K3s 安装拒绝全网 CIDR、弱/重复 Token、缺少 TLS Secret 和可变镜像引用。

12. 部署与离线迁移

12.1 当前形态

形态	用途	说明
直接 Python	本地开发/评审	python3 -m defensive_ai_gateway --config config/dev.yaml
Docker	隔离 Demo 或受控主机	容器默认本地规则，数据卷保存 SQLite
systemd	Linux 单机	环境文件提供 Token，回环监听，外部代理负责 TLS
k3s	内网部署参考	Gateway + 可选 Vector；ClusterIP/TLS Ingress；不可变镜像与回滚

12.2 生产替换点

Demo 组件	生产建议	迁移原则
SQLite	PostgreSQL / 企业关系库	先保持事实模型和幂等契约，再替换仓储实现
Embedded Syslog	Vector/Fluent Bit/企业 Collector	协议、缓冲、重试与应用分析解耦
Bearer Token	API Gateway + IAM + mTLS	保留角色和 actor 契约，不信任客户端自报
稳定哈希向量	企业 Embedding + pgvector	保留评分分解、阈值与审计
静态 Dashboard	SOC Portal / 企业前端	保留 API 和权限边界
内置审批	工单/SOAR/IAM	保留人工审批、幂等、回滚和执行回写

13. Demo 验收基线

13.1 2026-07-15 回放结果

项目	结果
批次	15 条 curated Demo alerts

项目	结果
产品	HIPS/RASP/NDR/WAF/SIEM，各 3 条
分类	malicious/suspicious/benign，各 5 条
Provider	gateway
Model	claude-sonnet-4-6
Fallback	15 条均 false
Worker	4
峰值观察	15 unfinished / 11 queued / 4 inflight
终态	15 completed / 0 dead-letter
耗时	最快 24.0 秒，最慢 211.8 秒

这些数据证明完整链路可运行，但不构成生产 SLA。真实 SLA 应在固定 Gateway、固定样本、稳定网络和代表性峰值流量下报告 P50/P95/P99。

13.2 Demo 验收场景

场景	验收点
五产品批量告警	durable 202、队列下降、每产品 Agent、Case 和审计完整
厂商原生 RASP JSON	指纹识别、auto profile、stack trace/sink 保留、映射失败拒绝
Gateway 正常	model_runtime 记录 gateway/model/fallback=false
Gateway 故障	本地降级、摘要和审计显式标记，不丢告警
提示注入	Validator review/blocked，不生成审批或可消费记忆
误报确认	disposition、长期记忆、匹配评分和后续降噪可追溯
高影响建议	approve_required、角色审批、execution_status=not_executed
进程重启	pending/retry/processing 恢复，completed 保持幂等

14. 生产差距与路线图

14.1 P0 : Demo 收口

- 19. 修复当前 2 个自动化测试断言，恢复全绿。
- 20. 建立不带 Demo 真值的脱敏盲测集，并锁定分析师标签。
- 21. 输出模型质量、延迟、失败/降级率和容量报告。
- 22. 用真实厂商日志完成至少一个 HTTP 和一个 Syslog 端到端验收。

23. 固化演示数据清理、批量提交、终态等待和故障注入脚本。

14.2 P1：企业 PoC

- 24. API Gateway/mTLS/SSO/IAM；
- 25. PostgreSQL 与备份恢复；
- 26. 企业 LLM Gateway、DLP、模型配额和审计；
- 27. CMDB/IAM/变更窗口的只读查询工具；
- 28. Collector 高可用、磁盘 buffer 和真实设备联调；
- 29. SOC Portal 或现有 Case 平台集成。

14.3 P2：评测与受控处置

- 30. Golden set、对抗集、模型/Prompt/Skill 版本差异报告；
- 31. CI 发布门禁和安全架构审批；
- 32. 工单/SOAR 独立执行适配器；
- 33. 双签、幂等、执行回写、回滚证据和异常补偿；
- 34. 记忆批量治理、语义聚类和组织知识同步。

15. 验收指标

指标分为“Demo 已验证”和“生产目标”，避免把目标写成事实。

维度	Demo 已验证	企业 PoC/生产目标
接入	15 条批量 durable 202，五产品路由正确	峰值回放无静默丢失，回压/DLQ/恢复可验证
模型	Gateway 15 条无 fallback，结构化结果可解析	盲测质量、证据正确率、P95/P99、降级率达标
证据	Case 可追溯到 RawAlert/Event/Run	高/严重 Case 100% 有 evidence refs 和缺口
安全	read_only、Validator、审批不执行	注入/越权阻断率、敏感泄漏为零、职责分离
记忆	生命周期和匹配分解可演示	真实误报解释时间下降，误降级受恶意证据否决
可用性	进程重启恢复、模型失败降级路径存在	HA、备份恢复、DR、月可用性和 RTO/RPO 达标
审计	全链路本地审计可查询	集中/WORM 审计、留存和监管检查达标

16. 结论

当前项目没有偏离“受控智能中枢”的原始路线，且已经具备一条可信的 Demo 主线：多源接入、证据归一化、持久排队、产品 Agent、真实 Gateway、确定性验证、受控审批、多层记忆、实时展示和审计。

下一阶段不应继续堆叠更多演示功能，而应把重点转向三件事：

- 35. 用盲测和容量数据证明质量；
- 36. 用企业身份、数据和基础设施完成真实 PoC；
- 37. 在不放松“AI 不直接执行生产动作”的前提下接入现有处置流程。

只有“推理能力、证据治理、权限边界、评测门禁、运营闭环”同时成立，防御 AI 才能从 Demo 进入银行 SOC。

附录 A：代码与文档映射

主题	主要位置
HTTP、鉴权、运行配置、Dashboard API	defensive_ai_gateway/app.py
SQLite Schema、队列、Case、审批、记忆、审计	defensive_ai_gateway/database.py
LLM Provider 与传输安全	defensive_ai_gateway/llm.py
Orchestrator、fallback、跨产品上下文	defensive_ai_gateway/orchestrator.py
Product Agent 与结果对齐	defensive_ai_gateway/agents/
Skill 与最小权限	defensive_ai_gateway/skills.py
Validator / Response Advisor	defensive_ai_gateway/validation.py、response.py
Mapping Profile	defensive_ai_gateway/log_adapter.py
Memory / Matcher	defensive_ai_gateway/memory.py、memory_matcher.py
Syslog	syslog_receiver.py、syslog_router.py、deploy/k3s/syslog-collector-vector.yaml
Demo / Harness	scripts/send_demo_alerts.py、scripts/run_harness.py
详细说明	README.md、docs/

附录 B：架构参考

资料	官方入口	本方案借鉴点
OpenAI Agents SDK	https://openai.github.io/openai-agents-python/	Agent、Handoff、Guardrail、Session、Human-in-the-loop、Tracing 等运行时思想；当前项目未直接依赖 SDK

资料	官方入口	本方案借鉴点
OWASP GenAI Security Project / LLM Top 10	https://genai.owasp.org/llm-top-10/	提示注入、敏感泄漏、供应链、过度代理和不安全输出风险
NIST AI Risk Management Framework	https://www.nist.gov/itl/ai-risk-management-framework	AI 风险识别、治理、测量与持续管理框架
MITRE ATLAS	https://atlas.mitre.org/	AI 系统攻击技术与检测/缓解思路

参考资料用于架构思想映射，不表示这些外部框架已经集成到当前 Demo。